

SessionBound: Turning Enterprise Task Approval into Budgeted Database Sessions

Minmin Wu
Independent Researcher

SessionBound: Turning Enterprise Task Approval into Budgeted Database Sessions

Safe Views, Budgets, and Receipts for Open-Ended Enterprise Analysis

Abstract

Enterprise AI agents are increasingly useful for internal analysis, audit, compliance review, and operational investigation. They are good at writing SQL on the fly, but enterprises cannot trust them with raw database access. These tasks are typically approved above the database layer by business users, managers, data owners, or compliance teams, but executed below that layer through open-ended SQL generated by an agent. This creates a missing systems layer: enterprise task approval must be translated into a database execution context that is bounded, budgeted, and auditable. SessionBound bridges this trust gap by turning a business approval into a short-lived, budgeted, and auditable database session.

We present **SessionBound**, a control-plane and database-runtime architecture that turns approved enterprise tasks into **budgeted database sessions** for AI agents. A SessionBound control plane defines task templates, accepts task applications, applies grants and approvals, assigns TTLs and budgets, and issues signed task tokens. A database runtime, **SessionBoundDB**, binds an approved task token to a short-lived agent session and enforces safe views, row scope, denied fields, operation limits, query budgets, disclosure budgets, and query receipts at SQL execution time.

SessionBound does not require the database to parse natural-language task descriptions, nor does it trust the agent or an LLM to correctly interpret or obey the task. The agent remains free to generate SQL, join safe business objects, aggregate, rank, and drill down. The database decides whether each attempt stays inside the approved boundary. This design targets a setting distinct from authenticated delegation, task-scoped service-operation authorization, and data-

product marketplace access: enterprise-internal analytical work where fixed SaaS screens are too rigid, direct database access is too broad, and approved tasks should become temporary, budgeted, receipt-bearing database sessions.

Code availability. The prototype source code and synthetic evaluation dataset are available at <https://github.com/SessionBound/sessionbound>.

1. Introduction

AI agents change how enterprise users interact with data. A user no longer needs to know which report exists, which dashboard to open, or which API endpoint to call. Instead, the user can ask an agent:

`Analyze June 2026 travel reimbursements for the Sales department.
Find unusual merchants, repeated claims, employee-level monthly totals,
and claims near approval thresholds. Exclude salary and bank data.`

This is exactly the kind of task agents are good at: temporary, exploratory, cross-table, and under-specified. It is also exactly the kind of task traditional enterprise software handles poorly. Building a permanent SaaS page or API for every low-frequency internal analysis task is expensive. Giving the agent raw database access is unsafe. Relying on prompts is not a security boundary. Relying on the application layer alone becomes fragile when SQL is generated dynamically.

The industry and research communities have already recognized several adjacent problems. OAuth 2.0 provides the standard delegated authorization model for web APIs [3]. Agent identity systems make agents visible and governable as non-human identities. Authenticated delegation frameworks let users verifiably delegate authority to agents [10]. Task-scoped authorization systems such as PAuth ask whether a specific API or tool operation is implied by the user’s task [9]. Data-product governance systems such as Data Product MCP connect enterprise data marketplaces with MCP so that agents can discover, request access to, and query governed data products [11, 4]. Database security systems such as Oracle Deep Data Security show that fine-grained policies should be enforced close to the data [6, 5]. Large-scale authorization systems such as Zanzibar show how relationship-based permission checks can be made consistent and global [7].

These are necessary pieces, but they leave a gap for enterprise-internal analytical agents. In real organizations, a manager or data owner does not log into a database to write row-level policies for every agent task. A business user applies for or delegates a task. A manager, data owner, or compliance workflow approves it. A data platform has already registered safe business views. A system must convert the approved task into a structured execution boundary that the database can enforce, while still allowing the agent to freely generate useful analytical SQL.

This paper argues for the following principle:

Business users approve tasks, not database policies.

Agents generate SQL, but databases enforce the approved boundary.

SessionBound separates three concerns.

1. **Task control plane.** Defines task templates, accepts task applications, evaluates grants and approvals, assigns budgets and TTLs, and signs task tokens.
2. **Agent execution.** Lets an LLM-powered agent decide what SQL to try, which hypotheses to test, and how to construct a temporary workspace.
3. **Database runtime.** Binds the signed task token to a database session and enforces safe views, scope, denied fields, operation limits, query budgets, disclosure budgets, and receipts.

The central design rule is:

The agent can try. The database decides.

This makes SessionBound a contract layer between enterprise approval and agentic database execution. The control plane records what the organization approved; the runtime enforces how that approval may be spent through SQL. This contract is not a database policy written by a DBA, nor a natural-language instruction interpreted by an LLM. It is a structured, signed, and accountable representation of an approved business task that both the agent runtime and the database can interpret deterministically.

SessionBoundDB is our PostgreSQL-based reference runtime for SessionBound. It does not ask an LLM whether a query is safe. It does not depend on the agent correctly interpreting the task. It does not trust mutable session variables set by the agent. Instead, it validates a signed task token, exposes only registered safe views, rejects raw table access and denied fields, tracks query and disclosure budgets, and records receipts for allowed and denied attempts.

The PostgreSQL prototype currently keeps the `taskbound` SQL schema name for compatibility with the existing demo implementation.

Contributions

This paper makes five contributions.

1. **Enterprise task approval as the missing layer.** We identify a gap between agent delegation and database enforcement: real enterprises approve tasks, scopes, and budgets above the database, but need those approvals translated into database-enforceable execution boundaries.
2. **SessionBound control plane.** We propose a task control plane with task templates, task applications, task approvals, grants, TTLs, budgets, and signed task tokens. This control plane lets business and data-governance

workflows define what work is authorized without requiring managers to write database policies.

3. **Budgeted database sessions.** We define a database session model in which an approved task token binds an agent to safe views, row scope, denied fields, allowed operations, TTL, query budget, disclosure budget, and audit receipt policy.
 4. **LLM-independent enforcement for open-ended SQL.** SessionBoundDB allows agents to generate SQL freely inside a boundary, but the database enforces that boundary deterministically. The database does not parse the natural-language task and does not rely on an LLM to judge safety at query time.
 5. **PostgreSQL prototype and hardening analysis.** We implement SessionBoundDB as a PostgreSQL-based runtime for SessionBound and demonstrate it on enterprise travel reimbursement analysis. We also analyze anti-evasion scope, budget semantics, schema drift, credential-token binding, receipt structure, and prototype-to-production hardening requirements.
-

2. Motivation: Enterprise Tasks Are Approved Above the Database

2.1 SaaS is strong at fixed workflows and weak at temporary analysis

Traditional SaaS applications are excellent for stable workflows. Expense systems have pages for submitting claims, approving them, and exporting reports. CRM systems have pages for accounts, opportunities, and pipeline forecasts. HR systems have forms for updating employee details. These interfaces are valuable because they encode product experience, business rules, and human responsibility.

But enterprises also contain many tasks that are temporary, analytical, and low-frequency:

- audit unusual reimbursement patterns for one month;
- compare vendor concentration across departments;
- investigate repeated support escalations for a customer segment;
- find transactions near policy thresholds;
- review access logs for a compliance incident;
- build a temporary workspace for a manager’s operational question.

These tasks are too specific to justify permanent SaaS pages, but too sensitive to give an agent raw database access. They often require joins, aggregation, ranking, drill-down, and follow-up queries. The exact SQL cannot be known in advance.

SessionBound targets this setting.

2.2 Enterprise approval is not database policy authoring

In a realistic enterprise, a manager or data owner should not be expected to write SQL policies. A business user might request:

```
Task type: monthly_expense_anomaly_review
Scope: June 2026, Sales department
Purpose: travel reimbursement audit
Sensitivity: exclude salary, phone, bank account
Budget: up to 20 SQL attempts, 5,000 result rows, and limited entity exposure
TTL: 30 minutes
```

A manager or data owner can decide whether this task is appropriate. A data platform can provide approved safe views. A compliance system can require tighter budgets. But none of these people should need to edit database roles, row-level security predicates, or cell-level policies for every agent session.

SessionBound therefore separates task governance from database enforcement:

```
Business users approve tasks.
Data platforms register safe views.
Control planes sign task tokens.
Databases enforce boundaries.
Agents explore freely inside those boundaries.
```

2.3 Running example: travel reimbursement anomaly review

We use travel reimbursement review as a running example. A finance analyst or department manager wants an agent to analyze June travel reimbursements for a department. The agent may need to:

- rank high-value claims;
- group expenses by merchant, city, category, and employee;
- compute monthly employee totals;
- find claims close to approval thresholds;
- drill down into suspicious patterns;
- propose follow-up review actions.

The agent should not see salary, bank account, phone number, or raw internal tables. It should not query another department, another month, or another tenant. It should not run DDL or arbitrary updates. It should not paginate through all employees and reconstruct an unrestricted dataset. Its access should expire quickly and leave an audit trail.

A fixed API such as `get_expense_summary(department, month)` is too narrow. A broad database account is too dangerous. A prompt instruction such as “do not access salary” is not a security mechanism. SessionBound’s answer is to approve a task and bind it to a database session with safe views, scope, budgets, and receipts.

3. Threat Model

SessionBound assumes the upper-layer agent is useful but not trusted. The agent may be confused, overconfident, prompt-injected, malicious, or simply wrong. The database boundary must remain meaningful even when the agent tries the wrong thing.

3.1 Trusted components

For this prototype, we trust:

- the task control plane that defines templates, evaluates grants, records approvals, and signs task tokens;
- the credential broker that issues short-lived database credentials;
- the database runtime that validates tokens and enforces policies;
- the cryptographic signing key or signing service used for task tokens;
- the integrity of registered safe views and runtime functions.

In production, the signing path should be backed by a KMS, JWKS, hardware-backed key service, or enterprise identity infrastructure. The prototype uses a simpler signing path for demonstration.

3.2 Untrusted or partially trusted components

We do not trust:

- the agent’s prompt;
- the agent’s reasoning;
- the agent’s SQL generation;
- the agent’s natural-language interpretation of the task;
- user-provided or database-provided text that may contain prompt injection;
- ordinary client-controlled session variables;
- application-layer filtering as the final boundary.

This is the main difference from designs that require an LLM to infer the precise intended operation from natural language. SessionBound does not ask the database to understand the user’s natural-language intent. The database consumes structured claims from a signed token.

3.3 In-scope threats

SessionBoundDB is designed to mitigate:

- **Sensitive field access:** attempts to read salary, bank account, phone, identity number, credentials, or private notes.
- **Raw table access:** attempts to bypass safe views and query application schemas directly.

- **Scope escape:** attempts to read other tenants, months, departments, projects, or users.
- **Unauthorized mutations:** attempts to run INSERT, UPDATE, DELETE, DDL, or high-impact operations outside controlled commands.
- **Prompt injection effects:** data or user text instructs the agent to ignore policy or reveal secrets.
- **Budget evasion:** repeated queries, pagination, or alternate SQL forms attempt to disclose more detail rows than the task allows.
- **Credential-token mismatch:** attempts to combine one runtime credential with another task token.

3.4 Out of scope

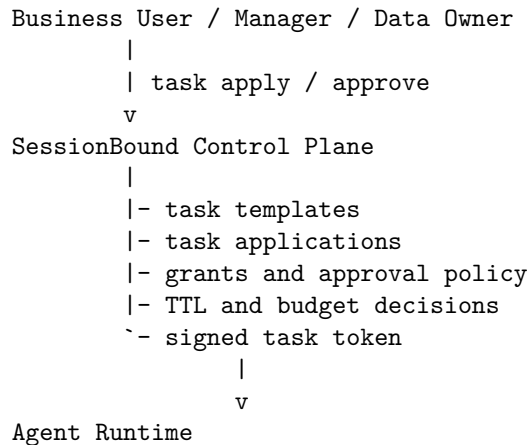
The prototype does not solve:

- malicious database administrators;
- compromised database host operating systems;
- compromised signing infrastructure;
- side-channel attacks;
- complete formal verification of SQL equivalence;
- production-grade SQL AST enforcement;
- cross-database federation;
- full differential privacy for statistical releases;
- arbitrary semantic inference across all allowed query answers.

SessionBound reduces and accounts for what an agent can discover. It does not claim to eliminate all inference.

4. SessionBound Model

SessionBound has two major layers: a task control plane and a database runtime.



```

      |
      | open-ended SQL
      v
SessionBoundDB Runtime
      |
      |- bind task token
      |- expose safe views
      |- enforce scope / denied fields
      |- track budgets
      `-- emit receipts

```

4.1 Task template

A task template is defined by a data platform or application team. It describes a class of work that can be safely delegated to agents once scoped and approved.

Example:

```

{
  "task_type": "monthly_expense_anomaly_review",
  "purpose": "travel_reimbursement_audit",
  "allowed_views": ["expenses", "employees", "departments"],
  "denied_columns": [
    "employees.salary",
    "employees.bank_account",
    "employees.phone"
  ],
  "required_scope": ["tenant_id", "expense_month", "department_id"],
  "allowed_operations": ["SELECT"],
  "default_ttl_minutes": 30,
  "default_budget": {
    "max_queries": 20,
    "max_result_rows": 5000,
    "max_unique_entities": {
      "expense_id": 5000,
      "employee_id": 200
    }
  }
}

```

The template is not generated by the agent. It is part of enterprise governance.

4.2 Task application

A task application is a concrete request to perform work under a template.

```

{
  "task_type": "monthly_expense_anomaly_review",

```



```

    "requested_by": "user:alice",
    "actor": "agent:travel-expense-analyst",
    "scope": {
        "tenant_id": "company_a",
        "expense_month": "2026-06",
        "department_id": "dep_sales"
    },
    "reason": "Review unusual travel reimbursement patterns."
}

```

4.3 Task approval

A task approval evaluates whether the requester may run this task with this scope and budget. Approval may be automatic, role-based, or manual. For sensitive tasks, a manager, data owner, or compliance reviewer may approve it.

The approval does not require the approver to write SQL policies. It decides whether this scoped task should exist.

4.4 Task token

A signed task token is the structured authorization object consumed by the database runtime.

```

{
    "task_id": "task_456",
    "task_type": "monthly_expense_anomaly_review",
    "delegator": "user:alice",
    "actor": "agent:travel-expense-analyst",
    "credential_id": "cred_123",
    "tenant_id": "company_a",
    "purpose": "travel_reimbursement_audit",
    "allowed_views": ["expenses", "employees", "departments"],
    "denied_columns": [
        "employees.salary",
        "employees.bank_account",
        "employees.phone"
    ],
    "row_scope": {
        "expense_month": "2026-06",
        "department_id": "dep_sales"
    },
    "operations": ["SELECT"],
    "budget": {
        "max_queries": 20,
        "max_result_rows": 5000,
        "max_unique_entities": {

```

```

        "expense_id": 5000,
        "employee_id": 200
    },
    "safe_view_registry_version": "travel-demo-v1",
    "policy_version": "expense-review-v1",
    "audience": "taskbounddb",
    "expires_at": "2026-06-24T10:30:00Z",
    "nonce": "...
}

```

4.5 Budgeted database session

A budgeted database session is a database session bound to one active task token. The session may issue open-ended SQL, but every attempt is checked against the token, safe view registry, operation policy, and remaining budget.

A connection may bind at most one active task token. Rebinding is denied. When the token expires or is revoked, further `taskbound.run` calls fail.

5. Control Plane: Templates, Applications, Approvals, and Budgets

The control plane is the SaaS-like layer that makes SessionBound realistic for enterprises. This is where SessionBound differs most clearly from database-only security systems.

5.1 Business users approve tasks, not policies

A data owner should see:

```

Alice requests a June Sales travel reimbursement anomaly review.
Scope: Sales department, June 2026.
Denied: salary, bank account, phone.
Budget: 20 queries, bounded entity exposure.
TTL: 30 minutes.

```

The data owner should not see:

```

CREATE POLICY ...
ALTER ROLE ...
GRANT SELECT ON ...

```

The control plane converts the business approval into a signed token that the runtime can enforce.

5.2 Grants and eligibility

Roles do not grant direct database access. They grant eligibility to request task templates. For example, a finance reviewer may be eligible to request finance-review tasks; a department manager may be eligible to request department-scoped analysis tasks.

This avoids broad database roles such as:

`finance_user can access all finance tables`

Instead, the database sees a concrete task token:

`agent X may analyze June 2026 Sales reimbursements using views A, B, C under budget Y.`

5.3 Budget assignment

Budget assignment is a control-plane decision. A low-risk task might receive a larger aggregate budget; a sensitive task may receive a small detail-row budget and a short TTL. Budgets can be adjusted by role, data classification, task purpose, and approval route.

The database runtime enforces the budget; the control plane decides what budget is appropriate.

6. SessionBoundDB Runtime

SessionBoundDB is the PostgreSQL-based database runtime for SessionBound.

6.1 Session binding and credential-token binding

The runtime begins with two objects:

1. a short-lived database credential issued by the credential broker;
2. a signed task token issued by the control plane.

The credential authenticates the runtime connection. The task token authorizes the work.

At `bind_task`, the runtime checks:

- the task token signature is valid;
- the task token is unexpired and not revoked;
- the credential is unexpired and not revoked;
- the token `credential_id` matches the current session credential;
- the token `actor` matches the credential actor;
- the session login role matches the broker-issued database user;
- the token audience is `taskbounddb`;
- no other active task is already bound to this database backend/session.

A stolen credential without a matching token is insufficient. A stolen token without the matching credential is insufficient. Credential-token binding reduces cross-task credential misuse.

PostgreSQL nuance: inside `SECURITY DEFINER` functions, `current_user` may refer to the function owner. Therefore, a production implementation should use `session_user` and/or an explicit credential registry mapping rather than relying on `current_user` alone.

6.2 Safe views as the query surface

Agents do not query raw application tables. They query registered safe views. Safe views expose business objects, not internal schemas. This is complementary to database-native mechanisms such as PostgreSQL row-level security policies, which provide row filtering at the database layer [8].

Example safe views:

```
expenses
employees
departments
approval_events
ledger_entries
```

A safe view may:

- join raw tables into business objects;
- remove sensitive fields;
- apply tenant, department, month, or project scope;
- expose workflow hints;
- include stable business identifiers for budget accounting.

Safe views are not a complete inference-control solution. They reduce the discoverable surface and make it governable.

6.3 Operation policy

`taskbound.run(sql)` is intended for read-only analytical SQL. High-value writes should use controlled commands or stored procedures. The runtime rejects mutations, DDL, unsafe utility commands, raw schema access, denied fields, and blocked schemas.

6.4 Query decision pipeline

At runtime, every SQL attempt follows a deterministic decision pipeline:

```
SQL Attempt
↓
Check active task binding
↓
```

```
Check task token validity
↓
Check allowed safe views
↓
Check denied fields
↓
Check row scope
↓
Check operation type
↓
Check query/disclosure budget
↓
Allow result + receipt
or
Deny + receipt
```

The runtime does not ask an LLM whether a query is safe.

7. Anti-Evasion Scope

SessionBound handles direct boundary violations, but it does not claim to eliminate all semantic inference attacks. This distinction is central to the design.

7.1 Direct boundary violations

SessionBoundDB can directly block:

- access to raw schemas;
- access to sensitive fields that are not exposed through safe views;
- queries outside row scope;
- unsupported operation types;
- repeated querying beyond task budgets;
- use of credentials without a matching task token;
- attempts to continue after token expiry or revocation.

7.2 Inference and side channels

SessionBound does not claim to solve arbitrary inference from allowed answers. For example, if a safe view exposes enough correlated information, an agent may infer sensitive facts indirectly. Aggregates over small groups may leak more than intended. Timing and resource side channels are also outside the prototype’s formal guarantees. Classical database inference-control work studies these risks for statistical databases and repeated query answers [1].

SessionBound’s position is therefore:

SessionBound reduces and accounts for the discoverable surface;

it does not eliminate all inference.

7.3 Adversarial SQL patterns

Pattern	Example	Defense	Limitation
Raw table escape	<code>SELECT * FROM app_data.expenses</code>	no raw grants; safe views only	strong in prototype
Sensitive column	<code>SELECT salary FROM employees</code>	denied fields; safe view exclusion	direct leakage only
Scope escape	query another month or department	safe-view predicates from task claims	strong if views are correct
Mutation	<code>DELETE, UPDATE, INSERT</code>	operation policy; read-only run path	writes require controlled commands
DDL	<code>DROP, ALTER, CREATE</code>	blocked operations	production should use AST validation
Catalog escape	<code>pg_catalog, information_schema</code>	blocked schemas and no grants	production needs parser/hooks
Pagination	repeated	query budget and	budget model
scraping	<code>LIMIT/OFFSET</code>	disclosure budget	matters
JSON / array	payload	result-byte	production
payload	aggregation	budget, per-query	should detect
aggregation	functions	payload cap, optional aggregate allowlist / AST policy	high-risk aggregation functions
Aggregate inference	small-group <code>GROUP BY</code>	optional minimum group size and aggregate policy	future work
Timing side channel	expensive predicates	statement timeout and resource budget	partial

This table is not a proof of complete SQL security. It defines the prototype's anti-evasion scope and the path toward production hardening.

Examples of payload aggregation patterns include:

```
SELECT json_agg(e) FROM expenses e;
SELECT array_agg(e.expense_id) FROM expenses e;
```

```
SELECT array_agg(row_to_json(e)) FROM expenses e;
SELECT string_agg(employee_name, ',') FROM employees;
```

The JSON / array aggregation case is particularly important. A result that appears to contain one row can still encode a large amount of data in a single JSON, array, XML, or string payload. For this reason, SessionBound budgets must include byte-level and payload-shape limits, not only row counters. A conservative prototype may deny high-risk aggregation functions such as `json_agg`, `array_agg`, `string_agg`, `xmllagg`, and `row_to_json` unless a task template explicitly allows them with a strict byte budget.

8. Budget Semantics

The phrase **disclosure budget** can be misleading if interpreted as differential privacy. SessionBound uses disclosure budgets for a different purpose.

Differential privacy protects statistical privacy, often by adding noise and accounting for privacy loss [2].

SessionBound disclosure budgets serve a different purpose. They limit how much task-authorized information an agent may retrieve or inspect during one approved analytical session. They are an authority-accounting mechanism, not a formal differential-privacy guarantee.

8.1 Budget vector

A production SessionBound deployment should use a budget vector rather than a single unique-row limit.

Example:

```
{
  "max_queries": 20,
  "max_result_rows": 5000,
  "max_result_bytes": 2000000,
  "max_payload_bytes_per_query": 250000,
  "max_json_array_elements": 1000,
  "max_unique_entities": {
    "expense_id": 5000,
    "employee_id": 200,
    "department_id": 20
  },
  "column_weights": {
    "expense_id": 1,
    "department_name": 1,
    "amount": 3,
    "employee_name": 5,
```

```

    "approval_reason": 8
  },
  "detail_multiplier": 1.0,
  "aggregate_multiplier": 0.2,
  "small_group_multiplier": 3.0,
  "blocked_or_weighted_functions": {
    "json_agg": "block_or_charge_high",
    "array_agg": "block_or_charge_high",
    "string_agg": "block_or_charge_high",
    "xmlagg": "block_or_charge_high"
  }
}

```

8.2 Budget dimensions

The runtime may account for:

- **query count**: limits repeated attempts;
- **result rows**: limits raw output volume;
- **result bytes**: limits bulk export;
- **per-query payload bytes**: prevents one-row JSON, array, XML, or string payloads from smuggling a large relation as a single tuple;
- **aggregate payload shape**: optionally blocks or heavily charges high-risk aggregation functions such as `json_agg`, `array_agg`, `string_agg`, and `xmlagg`;
- **unique business entities**: tracks exposure of objects such as expenses, employees, tickets, or customers;
- **column weights**: charges more for more sensitive exposed attributes;
- **detail versus aggregate multipliers**: charges detail rows more than coarse aggregates;
- **small-group penalties**: charges more when aggregates describe very small groups.

The prototype’s unique-row accounting demonstrates the mechanism. The research model is broader: a budget is a vector of exposure counters tied to task authority.

8.3 Budget limitations

Budget vectors are not formal mutual-information bounds. They do not prove that an agent cannot infer a sensitive fact from allowed answers. They provide operational containment, auditability, and a practical governance lever for approved enterprise tasks.

9. Schema Drift and Safe View Versioning

Task tokens should not silently survive changes to the data boundary they approve. If a safe view changes after approval, the token may no longer represent the approved task.

9.1 Binding model

A task token should bind safe views by more than name. For each safe view, the token or registry state should include:

```
safe_view_id
safe_view_registry_version
policy_version
database_object_oid
view_definition_hash
safe_column_list_hash
```

PostgreSQL nuance: ordinary tables have physical storage files, but views do not behave like ordinary stored relations. Binding to `relfilenode` is not appropriate for views. `pg_class.oid` is useful but insufficient: `CREATE OR REPLACE VIEW` may preserve the OID while changing the definition. Therefore, `SessionBound` should compare view definition hashes and registry versions.

9.2 Drift behavior

Change	Risk	Required Response
Add column to raw table	hidden exposure if safe view uses <code>SELECT *</code>	safe views must not use <code>SELECT *</code> ; registry hash unchanged if not exposed
Add column to safe view	new exposure	invalidate existing task tokens
<code>CREATE OR REPLACE VIEW</code>	semantics drift	compare view definition hash; invalidate if changed
<code>DROP/CREATE VIEW</code>	object replacement	OID mismatch; invalidate
Policy version update	approval drift	invalidate or require explicit compatibility flag
Column type change	interpretation drift	invalidate if exposed column hash changes

A task-bound session should fail closed if its safe view registry version or view definition hash no longer matches the approved boundary.

10. Receipts

SessionBound receipts are structured audit records that bind task identity, query decision, and budget impact. They are not merely logs.

A receipt may contain:

```
{
  "receipt_id": "receipt_789",
  "task_id": "task_456",
  "actor": "agent:travel-expense-analyst",
  "query_hash": "...",
  "views_touched": ["expenses"],
  "decision": "allowed",
  "rows_returned": 120,
  "budget_delta": {
    "queries": 1,
    "result_rows": 120,
    "weighted_disclosure": 240
  },
  "budget_remaining": {
    "queries": 19,
    "weighted_disclosure": 9760
  },
  "timestamp": "2026-06-24T10:05:00Z",
  "previous_receipt_hash": "...",
  "receipt_hash": "..."
}
```

For the arXiv prototype, the recommended implementation is a lightweight hash chain: each receipt stores `previous_receipt_hash` and `receipt_hash`, where the current hash commits to the task id, query hash, decision, budget delta, timestamp, and previous hash. This does not provide a full external proof system, but it makes post-hoc tampering with the receipt sequence detectable within the database audit trail. Future work can explore Merkle receipts, verifiable audit logs, cryptographic accumulators, and external notarization.

11. Prototype Implementation and Production Hardening

11.1 Prototype

The current prototype includes:

- FastAPI control plane;
- task template and grant registry;

- short-lived PostgreSQL credential broker;
- signed task token issuance;
- PostgreSQL runtime functions;
- safe views over travel reimbursement data;
- `taskbound.bind_task(payload, signature)`;
- `taskbound.run(sql)`;
- sensitive field denial;
- blocked raw table access;
- query and disclosure budget state;
- receipts for allowed and denied attempts;
- controlled commands for high-value workflow actions;
- an agent-agnostic HTTP evaluation harness.

The prototype demonstrates the SessionBound architecture, not a production-grade SQL safety proof.

11.2 Implementation honesty

The current prototype uses conservative SQL checks plus PostgreSQL permissions. Agents do not receive raw schema grants. Agents call `taskbound.run(sql)`. The runtime role cannot access `app_data` directly. Safe views are the query surface. High-value writes go through controlled commands.

A production implementation should move beyond string-level checks to:

- SQL AST validation;
- PostgreSQL parser hooks;
- planner hooks;
- executor hooks;
- extension-level enforcement;
- deny-by-default schema grants;
- blocked unsafe utility commands;
- `statement_timeout` and resource limits;
- cleanup for expired short-lived roles;
- denial logging outside user transactions.

11.3 Query example

Allowed:

```
WITH ranked AS (
  SELECT expense_id, department_name, category, amount,
         row_number() OVER (
           PARTITION BY department_name ORDER BY amount DESC
         ) AS rn
  FROM expenses
  WHERE expense_month = '2026-06'
)
```

```
SELECT department_name, expense_id, category, amount
FROM ranked
WHERE rn = 1;
```

Denied:

```
SELECT employee_name, salary FROM employees;
```

Denied:

```
SELECT * FROM app_data.expenses;
```

Denied:

```
DELETE FROM expenses WHERE expense_month = '2026-06';
```

12. Evaluation

The first evaluation has two goals:

1. validate that approved analytical queries can run over safe views;
2. validate that direct boundary violations are denied and accounted for.

It does not prove production-grade SQL safety or eliminate all inference attacks.

12.1 Functional scenario suite

We evaluated the imported PostgreSQL prototype after the public SessionBound rename at commit `f793787` using Docker Compose, PostgreSQL 16.14, and the FastAPI task-token and dynamic-credential API. The detailed validation run passed 18 of 18 tested scenarios. The core allowed query patterns worked, and direct sensitive-field, raw-schema, mutation, DDL, query-budget, unique-row disclosure-budget, and payload-aggregation violations were denied.

Scenario	SQL Feature / Attack	Expected	Observed
Safe view SELECT	SELECT	Allowed	Allowed
Join safe views	JOIN	Allowed	Allowed
Department totals	GROUP BY	Allowed	Allowed
CTE	common table expression	Allowed	Allowed
Ranked claims	window function	Allowed	Allowed
Salary access	denied column	Denied	Denied
Bank account access	denied column	Denied	Denied
Raw table access	schema escape	Denied	Denied

Scenario	SQL Feature / Attack	Expected	Observed
Other month	scope escape	Transparent scope filtering	Transparent scope filtering
Mutation SQL	DELETE	Denied	Denied
DDL	DROP	Denied	Denied
Query budget overflow	excessive queries	Denied	Denied
Disclosure budget overflow	too many unique expense rows	Denied	Denied
pg_catalog access	catalog escape	Denied	Denied
json_agg(e) payload	aggregation payload	Denied	Denied
array_agg(e.expense_id) payload	aggregation payload	Denied	Denied
string_agg(employee_name, ',') payload	aggregation payload	Denied	Denied
row_to_json(e) payload	aggregation payload	Denied	Denied

Scope violations over safe views are enforced by filtering rather than explicit denial. A query for another approved-view but out-of-scope month returns zero rows because the safe view predicate binds the session to the task scope. The v1 prototype conservatively blocks payload aggregation functions such as `json_agg`, `array_agg`, `string_agg`, and `row_to_json`; ordinary aggregate analysis such as `count`, `sum`, `avg`, `min`, and `max` remains allowed.

12.2 Performance microbenchmark

A system paper must report overhead. The v5 evaluation should compare raw PostgreSQL execution against `taskbound.run(sql)` for core query patterns.

Benchmark patterns:

1. simple `SELECT`;
2. `JOIN` over safe views;
3. `GROUP BY` aggregation;
4. CTE;
5. window function.

Metrics:

- PostgreSQL version;
- Docker / hardware environment;
- commit hash;

- number of iterations;
- p50 latency;
- p95 latency;
- mean latency;
- standard deviation;
- rows returned;
- overhead percentage.

We ran a microbenchmark at commit `cb2d4ca` with 10 warmup iterations and 100 measured iterations per query pattern. The baseline is an admin/test role executing equivalent SQL over raw `app_data` tables with tenant and month predicates matching the task scope. The SessionBound path binds a signed task token and executes `taskbound.run(sql)` in PostgreSQL. The benchmark intentionally excludes HTTP latency and dynamic credential creation so that it focuses on database runtime overhead.

Pattern	Raw p50	SB p50	Overhead	Rows
SELECT	0.063 ms	1.434 ms	2168.4%	3
JOIN	0.060 ms	1.503 ms	2408.0%	3
GROUP BY	0.066 ms	1.450 ms	2088.7%	3
CTE	0.052 ms	1.457 ms	2702.8%	1
Window	0.074 ms	1.500 ms	1937.5%	5

SB denotes SessionBound. The corresponding raw/SB p95 pairs were: SELECT 0.142/1.760 ms; JOIN 0.135/1.752 ms; GROUP BY 0.139/1.709 ms; CTE 0.102/1.694 ms; and Window 0.157/1.814 ms.

The prototype adds overhead compared with raw PostgreSQL, but absolute p50 latency remains around the low-millisecond range for the benchmarked query patterns. The absolute SessionBound p50 latency is approximately 1.4–1.5 ms on these small synthetic queries. Relative overhead is high because the raw PostgreSQL baseline is extremely small. The likely sources are PL/pgSQL runtime dispatch, SQL text checks, task-session lookup, safe-view evaluation, query-budget updates, unique-row exposure accounting, payload-aggregation checks, and receipt insertion. These microbenchmark results should not be generalized to larger datasets without additional experiments.

12.3 Threat-to-defense matrix

Threat	SessionBound Defense
Agent ignores task	database enforces signed task token
Prompt injection	safe views, denied fields, budgets
Raw table access	no raw schema grants
Sensitive field access	denied columns and safe view exclusion

Threat	SessionBound Defense
Scope escape	row scope in safe views
Unauthorized writes	read SQL blocked; writes via controlled commands
Query flood	query budget
Cumulative detail exposure	disclosure budget vector
Credential leakage	short-lived DB credential plus task-token binding
Audit gap	task receipts
Schema drift	safe view version and definition hash checks

13. Related Work

13.1 OAuth, agent identity, and authenticated delegation

OAuth 2.0 and related standards support delegated API access [3]. Agent identity systems make agents visible and manageable as first-class non-human identities. Authenticated delegation frameworks make it possible to verify that an agent is acting on behalf of a user and that a credential carries scope [10].

SessionBound can build on these systems. Authenticated Delegation establishes who may act for whom; SessionBound turns approved enterprise tasks into enforceable database sessions.

13.2 PAuth and task-scoped service operations

PAuth provides precise task-scoped authorization for service or tool operations [9]. It derives NL slices from a task and checks that concrete operations and operands match task-implied computations.

SessionBound is complementary. It does not attempt to verify that every SQL query is semantically implied by a natural-language request. Instead, it enforces the approved task boundary over open-ended SQL using structured tokens, safe views, budgets, and receipts. In short, PAuth checks whether an operation is implied by the task description; SessionBound checks whether an agent’s SQL exploration stays within a pre-approved, structured task boundary.

13.3 Data Product MCP and enterprise data product governance

Data Product MCP integrates data-product marketplaces and MCP so agents can discover, request access to, and query enterprise data products [11]. The Model Context Protocol standardizes tool connectivity for agent systems [4]. Data Product MCP is the closest related work to SessionBound’s enterprise governance motivation.

SessionBound differs by making the approved task session, not the data product, the primary runtime object. A SessionBound session may span multiple safe views

and account for cumulative exposure across queries. Its core abstraction is the budgeted database session created from task approval. In short, Data Product MCP governs access to data products; SessionBound governs the execution session of an exploratory agent.

13.4 Oracle DDS and database-enforced access control

Oracle Deep Data Security and related systems show that database-enforced access control for agentic AI, AI-assisted applications, direct exploratory access, and analytics is an important industry direction [6, 5]. Such systems are strong data-plane enforcement mechanisms.

SessionBound does not claim that this broad direction is new. It adds an enterprise task control plane and task-bound session model around database enforcement: templates, applications, approvals, signed task tokens, budgets, receipts, and safe-view versioning. In short, Oracle DDS enforces identity- and context-aware database policies; SessionBound provides the task control plane that turns business approval into a bounded, budgeted database session without requiring business users to write SQL predicates.

13.5 Zanzibar and relationship-based authorization

Zanzibar provides a consistent, global relationship-based authorization system [7]. It performs relationship-based authorization checks at global scale.

SessionBound models budgeted database sessions for agent-generated analysis: once an enterprise task is approved, how should an agent’s database session be bounded, budgeted, and audited while it generates SQL?

13.6 Differential privacy, inference control, query auditing, and DLP

Differential privacy and database inference control address leakage from query answers, often in statistical settings [2, 1]. Query auditing and DLP systems track or prevent sensitive data disclosure.

SessionBound is related but does not claim formal DP guarantees. Its disclosure budget is operational accounting for delegated task authority. It limits cumulative exposure during a task session and produces receipts for governance and audit.

14. Future Work

SessionBound opens several research and engineering directions beyond the first prototype.

First, **cross-database and lakehouse federation** would extend task-bound sessions beyond a single PostgreSQL runtime. A production deployment may need to bind one approved task to Snowflake, BigQuery, PostgreSQL, vector

stores, and lakehouse tables while preserving one budget, one approval record, and one receipt chain.

Second, **production-grade SQL enforcement** should move from conservative checks and database permissions toward parser-, planner-, or executor-level enforcement. This includes AST validation, PostgreSQL hooks, aggregate-function policies, catalog-access controls, and robust handling of generated SQL equivalence.

Third, **stronger disclosure accounting** is needed. The current budget-vector model is operational rather than formal. Future work should explore sensitivity-aware budgets, aggregate leakage models, minimum group-size policies, reconstruction-risk detection, and possible integration with differential-privacy mechanisms where statistical guarantees are required.

Fourth, **verifiable receipts** can strengthen the audit layer. The prototype can use structured or hash-chained receipts; future versions could use Merkle trees, append-only transparency logs, cryptographic accumulators, or external notarization to make query receipts tamper-evident across organizational boundaries.

Fifth, **safe-view authoring and verification** should become a first-class developer workflow. Data platform teams need tools to lint safe views, detect accidental `SELECT *`, compare view-definition hashes, test adversarial SQL patterns, and verify that view changes invalidate or reissue affected task tokens.

Finally, SessionBound raises a broader question: how should enterprise software represent work units for AI agents? Task templates, approvals, budgets, receipts, and handoffs may become common infrastructure for agentic enterprise systems, not just database analysis.

15. Limitations

SessionBound is a research prototype and reference architecture.

Current limitations include:

- SQL validation is not production-grade AST enforcement;
- the prototype targets a single PostgreSQL database;
- HMAC/demo signing should be replaced with KMS/JWKS-backed signing;
- disclosure budgets are operational, not formal DP;
- semantic inference is reduced and accounted for, not eliminated;
- out-of-scope predicates over safe views return no rows through transparent scope filtering rather than producing an explicit denial;
- payload aggregation functions are conservatively blocked rather than governed by a per-template allowlist in the v1 prototype;
- safe views require careful review and versioning;

- view drift invalidation is a design requirement but may not be fully implemented in the prototype;
- current performance results are microbenchmarks over small synthetic data and should not be generalized to production workloads;
- denial receipts may require out-of-transaction logging in production;
- cross-database federation and lakehouse enforcement are future work;
- malicious DBAs and compromised hosts are out of scope.

These limitations are acceptable for a first research prototype if stated clearly and evaluated honestly.

16. Conclusion

SessionBound turns enterprise task approval into budgeted database sessions for AI agents. It addresses a gap between business governance and database enforcement: business users approve tasks, data platforms register safe views, agents generate SQL, and databases enforce the approved boundary.

SessionBound is not a replacement for OAuth, authenticated delegation, PAuth, Data Product MCP, Oracle DDS, Zanzibar, or differential privacy. It is a complementary architecture for enterprise-internal analytical work: temporary tasks that are too flexible for fixed SaaS screens and too sensitive for raw database access.

SessionBoundDB, our PostgreSQL runtime, demonstrates how signed task tokens, safe views, denied fields, row scope, query budgets, disclosure budgets, and receipts can be bound to one database session. The result is a practical contract between enterprise task approval and agentic database execution:

The agent can try. The database decides.

References

- [1] N. R. Adam and J. C. Wortmann. Security-Control Methods for Statistical Databases: A Comparative Study. *ACM Computing Surveys*, 21(4):515–556, 1989.
- [2] Cynthia Dwork and Aaron Roth. *The Algorithmic Foundations of Differential Privacy*, volume 9 of *Foundations and Trends in Theoretical Computer Science*. Now Publishers, 2014.
- [3] D. Hardt. The OAuth 2.0 Authorization Framework. RFC 6749, 2012.
- [4] Model Context Protocol. *Model Context Protocol Specification*, 2025.
- [5] Oracle. *Oracle Deep Data Security Technical Brief*. Oracle, 2026.
- [6] Oracle. *What Is Oracle Deep Data Security*. Oracle, 2026.

- [7] Ruoming Pang, Ramon Caceres, Mike Burrows, Zhifeng Chen, Pratik Dave, Nathan Germer, Alexander Golynski, Kevin Graney, Nina Kang, Lea Kissner, Jeffrey L. Korn, Abhishek Parmar, Christina D. Richards, and Mengzhi Wang. Zanzibar: Google’s Consistent, Global Authorization System. In *2019 USENIX Annual Technical Conference (USENIX ATC 19)*, pages 33–46. USENIX Association, 2019.
- [8] PostgreSQL Global Development Group. *Row Security Policies*. PostgreSQL, 2026.
- [9] Reshabh K. Sharma, Linxi Jiang, Zhiqiang Lin, and Shuo Chen. PAuth - Precise Task-Scoped Authorization For Agents, 2026.
- [10] Tobin South, Samuele Marro, Thomas Hardjono, Robert Mahari, Cedric Deslandes Whitney, Dazza Greenwood, Alan Chan, and Alex Pentland. Authenticated Delegation and Authorized AI Agents, 2025.
- [11] Marco Tonnarelli, Filippo Scaramuzza, Simon Harrer, and Linus W. Dietz. Data Product MCP: Chat with your Enterprise Data, 2026.